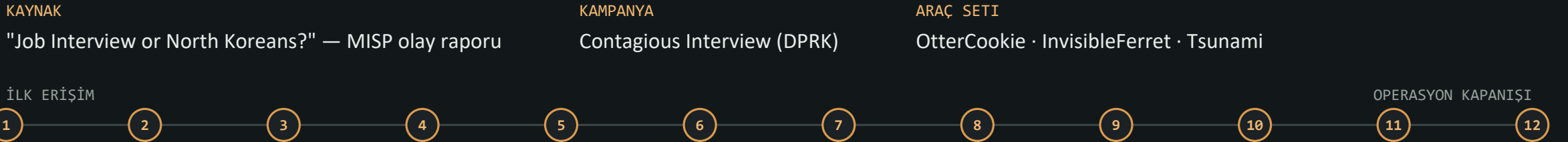


Contagious Interview: Bir "İş Görüşmesi" Nasıl Uzak Erişim Truva Atına Dönüştü

Komut satırı seviyesinde teknik post-mortem: her adımda ne çalıştı, neden bu şekilde tasarlandı, hangi MITRE ATT&CK tekniğine karşılık geldi ve savunma tarafı ne yapmalıydı.



00

Bugün Neye Bakacağız

› 01 — Kampanya Bağlamı

Contagious Interview nedir, neden önemli

› 02 — Saldırı Zinciri

İlk erişimden operasyonun kapanışına, 12 faz — her adımda gerçek komut satırı ve o komutun karşılık geldiği MITRE ATT&CK tekniği

› 03 — Base64 Örnekleri

Vakada geçen iki gizlenmiş payload'ı birlikte çözeceğiz: encode edilmiş hali ve decode edilmiş gerçek hali

› 04 — Vaka İstatistikleri

Tespit hızı, kurban sayısı, kampanya ölçeği

› 05 — Neden Bu Kadar Etkili?

Saldırının tasarım mantığı

› 06 — Blue Team Çerçevesi

Savunma tarafı bu vakada ne yapmalıydı, neye dikkat etmeliydi — teknik ve süreç önerileri

Yönetici Özeti

- › Vaka, DPRK rejimine gelir sağlamayı amaçlayan devam eden bir operasyon olan Contagious Interview kampanyasının parçası.
- › Saldırgan, C2 altyapısını işletmek için socket.io-client, axios, request gibi meşru, herkesin güvendiği npm paketlerine “bindi”.
- › Modüler, çok aşamalı bir araç seti (OtterCookie, InvisibleFerret, Tsunami) ilk erişim, kalıcılık ve çoklu OS dağıtımını tek zincirde birleştirdi.
- › Dosya sızdırma, wallet / seed / mysql / .ssh / keypair gibi anahtar kelimelerle yüksek değerli veriye öncelik verecek şekilde tasarlandı.
- › Bu rapor temel alınarak savunma tarafında iki yeni tespit kuralı eklendi — bu sunumun kapanışında hangi kuralların eklenmiş olabileceğini de tartışacağız.

Kampanya Bağlamı: Neden "İş Görüşmesi"?

› Contagious Interview

2023 sonundan bu yana izlenen, DPRK bağlantılı tehdit aktörlerinin yürüttüğü bir sosyal mühendislik + malware dağıtım deseni.

› Hedef

Kripto para ve yazılım ekosistemlerindeki geliştiriciler/mühendisler — ağırlıklı olarak macOS kullanıcıları — sahte iş ilanları ve teknik değerlendirme görevleri üzerinden.

› Fark

Klasik phishing'den farklı olarak hedefin kendi isteğiyle, güvendiği bir bağlamda kod indirip çalıştırmasını sağlar.

› Bu vakada tuzak

InfiniGodsOrg/RealEstate_Marketplace — gayrimenkul ilan sitesi görünümü, gerçekten çalışan bir GitHub deposu; "klonla, çalıştır, bir özellik geliştir" tarzı bir teknik mülakat görevi olarak sunulmuş.

03

Saldırı Zinciri — 12 Faz

- › 1. İlk erişim — sahte repo klonlanıyor, gizli C2 adresi base64 ile saklanıyor
- › 2. “Font dosyası” kılığındaki backdoor çalışıyor (Masquerading)
- › 3. Meşru npm paketleriyle C2 hattı kuruluyor — OtterCookie (sandbox evasion + WebSocket) ve InvisibleFerret (dosya tarama)
- › 4. İlk Suricata alarmları — ağ tabanlı tespit (54. saniye)
- › 5. Taşınabilir Python çalışma zamanı + InvisibleFerret indiriliyor (LOLBin: tar.exe)
- › 6–9. Bootstrap → keylogger/RAT (way) → tarayıcı hırsızlığı + Tsunami (pow) → sahte web app açılıyor (2. base64 örneği)
- › 10. İkinci, bağımsız ekran/klavye gözetim katmanı
- › 11. Elle keşif (hands-on-keyboard) ve operatörün çekilmesi
- › 12. Geniş resim — 13 eşzamanlı kurban

Her fazın sağ üst köşesinde o adımda kullanılan MITRE ATT&CK tekniğini göreceksiniz — bu bir özet tablo değil, komut komut ilerleyen bir harita.

İlk Erişim — Sahte Repo Klonlanıyor

```
process git.exe clone https://github.com/InfiniGodsOrg/RealEstate_Marketplace.git \
  %USERPROFILE%\Documents\RealEstate_Marketplace --progress --recursive
```

- recursive** Repodaki submodule'leri de otomatik klonlar — ek gizli bağımlılık taşıyabilir.
- progress** İlerleme çubuğu gösterir — kurbanı “her şey normal” hissi veren zararsız bir detay.

NEDEN BU ADIM KRİTİK

Statik URL/domain kara listeleri işe yaramaz — repo klonlandığı anda zararsız görünür. Gerçek C2 adresi repo içinde, config.env dosyasında sahte bir “API anahtarı” olarak gizlenmiş. Bir sonraki slaytta bu anahtarı birlikte çözeceğiz.

git: dağıtık versiyon kontrol sistemi, kod geçmişini takip eder · GitHub: git depolarını barındıran, geliştiricilerin işbirliği yaptığı bulut platformu.

Base64 ile Gizlenmiş C2 Adresi

CONFIG.ENV İÇİNDEKİ SAHTE API ANAHTARI (BASE64)

aHR0cHM6Ly9qc29ua2VlcGVyLmNvbS9iL0dPU1pZ

BASE64 DECODE

DECODE EDİLMİŞ HALİ — GERÇEK C2 KONFIGÜRASYON ADRESİ

<https://jsonkeeper.com/b/GOSZY>

BU ADIMIN ÖNEMİ

jsonkeeper.com meşru, herkese açık bir JSON paylaşım servisi — pastebin'in JSON'a özel bir versiyonu gibi düşünün. Saldırgan C2 konfigürasyonunu (asıl komuta-kontrol adresini) repo dışına, itibarlı bir üçüncü parti servise taşıyarak hem statik kod analizini hem domain itibar kontrollerini atlatıyor. Bu adreste daha fazla obfuscated edilmiş kod barınıyor.

Base64: ikili veriyi harf/rakamdan oluşan metne çeviren, şifreleme değil sadece kodlama olan bir yöntem — herkes tarafından anında geri çözülebilir, gizliliği değil sadece “görünmezliği” sağlar.

FAZ 02

MASQUERADE FILE TYPE (T1036.008)

"Font Dosyası" Kılığındaki Backdoor

```
process %WINDIR%\System32\cmd.exe /d /c (command -v node >/dev/null 2>&1 &&  
node ./public/fontawesome/fa-solid-400.woff2) || (where node >nul 2>&1 &&  
node ./public/fontawesome/fa-solid-400.woff2) || echo ''
```

/d cmd.exe açılırken registry AutoRun anahtarını çalıştırmaz — ortamı “temiz” tutar.

command -v / where Üç farklı işletim sistemi ailesini tek satırda destekleyen taşınabilir kalıp.

.WOFF2 BİR FONT DEĞİL

Node, dosya uzantısına bakmaksızın içeriği JavaScript olarak çalıştırır — klasik bir masquerading tekniği, yüzeysel taramaları yanıltır.

woff2 (Web Open Font Format 2): web sitelerinde küçük dosya boyutuyla özel yazı tipi göstermek için kullanılan, sıkıştırılmış bir font dosyası formatı — normalde hiçbir çalıştırılabilir kod içermez.

Meşru Paketlerle "Güvenilir" C2 Hattı

```
process cmd.exe /d /s /c "cd %TEMP%\programx64 && npm install axios && node main.js"
process node -e "function _0x267c(){const _0x5f1b45=['hostname',...
```

› --no-save + sessiz bayraklar

Paket package.json'a yazılmaz, kurulum konsolda hiçbir çıktı üretmez.

› node -e — dosyasız çalıştırma

Diske dosya yazılmaz; dosya-tabanlı AV taramaları göremez, EDR telemetrisi hala görür.

› obfuscator.io tarzı gizleme

Değişken adları hex dizilerine çevrilmiş, string'ler tek dizide toplanmış — imza tabanlı tespiti zorlaştırır.

npm: Node.js için paket yöneticisi, milyonlarca hazır kod kütüphanesini tek komutla indirir · axios: en yaygın kullanılan HTTP istemci kütüphanelerinden biri, web sunucularına istek atmak için kullanılır · obfuscator.io: kaynak kodu insan tarafından okunmaz hale getiren, herkese açık ücretsiz bir web aracı.

Payload A — OtterCookie: Fingerprint + Sandbox Evasion

```
process wmic computersystem get model,manufacturer
# macOS: system_profiler SPHardwareDataType
# Linux: /proc/cpuinfo içinde hypervisor|kvm|xen|qemu taranır
```

› "(VM)" / "(Local)" etiketi

Üç işletim sisteminde de sanallaştırma kontrolü — sonuç C2 paneline etiket olarak düşüyor, operatör gerçek makineleri öncelikliyor.

› Kalıcı WebSocket C2

socket.io-client ile açılan kanal üzerinden gelen “command” olayları doğrudan exec()’e veriliyor — gerçek zamanlı, etkileşimli erişim.

wmic: Windows’ta donanım/sistem bilgisi sorgulamak için kullanılan yerleşik komut satırı aracı · WebSocket: sunucu ve istemcinin, tek bir bağlantıyı açık tutarak istediği an birbirine mesaj gönderebildiği iletişim protokolü (klasik istek-cevap yerine sürekli iki yönlü kanal) · socket.io: WebSocket üzerine kurulu, gerçek zamanlı iletişimi kolaylaştıran popüler bir JavaScript kütüphanesi.

Payload B — Dosya Sistemi Tarayıcı ve Sızdırma

```
process wmic logicaldisk get name
# Recursive tarama, node_modules/.git/AppData haric tutulur
# Eslesme: *wallet* *seed* *keypair* *.ssh* *.env* *mysql* *.pdf* *.doc*
```

AKILLI ÖNCELİKLENDİRME

Kalan dosyalar joker karakterli desenlerle eşleştirilip FormData ile multipart POST olarak C2'ye yükleniyor — kripto cüzdan, SSH anahtarı ve kimlik bilgisi dosyalarına öncelik veriliyor.

FormData / multipart POST: tarayıcıların ve uygulamaların dosya yüklerken kullandığı standart, meşru HTTP veri biçimi — normal bir dosya yükleme isteğinden ayırt edilmesi ağ seviyesinde zordur.

FAZ 04

TESPİT ANI

Ağ Tespiti — İlk Suricata Alarmları

C2 trafiğinin başlamasının hemen ardından iki Suricata imzası tetiklendi — Time to Discovery istatistiği (54 saniye) tam olarak bu ana denk geliyor. Suricata: ağ trafiğini gerçek zamanlı izleyip bilinen kötü amaçlı desenlerle eşleştiren, açık kaynak bir saldırı tespit sistemi (IDS/IPS).

ZAMAN	KAYNAK	İMZA / DETAY
T+00:54	216.126.237.99:1271	"ETPRO MALWARE Nodster CnC Activity POST"
T+00:54	216.126.237.99:1271	"ET MALWARE OtterCookie Host Profile Exfil"

FAZ 05

INGRESS TOOL TRANSFER (T1105)

Taşınabilir Python + LOLBin ile 2. Aşama

```
process cmd.exe /d /s /c "tar -xf %TEMP%\p2.zip -C C:\Users\REDACTED"  
# 88.218.0.78:1224/pdown -> p.zip (gomulu Python + kutuphaneler)
```

› tar.exe neden dikkat çekici (LOLBin)

Windows'ta yerleşik gelen bir ikili — harici arşiv aracı indirmenin bırakacağı izi ortadan kaldırır. LOLBin: “Living-off-the-Land Binary”, işletim sistemiyle birlikte zaten gelen, meşru bir aracın kötü amaçla kullanılması.

› Üç InvisibleFerret payload'ı

main6_818.py (.nql), pay6_818.py (way), brow6_818.py (pow) — sıradan görünen gizli dosya adlarıyla diske yazılıyor.

› Katmanlı gizleme

İçerik zlib ile sıkıştırılıp base64 kodlanıyor, ters çevriliyor ve exec() içine 64 kez iç içe veriliyor — “soğan katmanı” gizleme. zlib: veri sıkıştırma kütüphanesi; burada gizlemeyi güçlendirmek için base64 ile birlikte kullanılıyor.

FAZ 07

INPUT CAPTURE (T1056.001)

CLIPBOARD DATA (T1115)

"way" — Keylogger ve Özel RAT Protokolü (Port 2246)

UUID = SHA-256(MAC + kullanıcı adı) ile kararlı kurban kimliği üretiliyor; konum ip-api.com gibi ücretsiz bir geo-IP servisinden çekiliyor. AnyDesk: meşru, dijital imzalı bir uzak masaüstü yazılımı — burada kötüye kullanılıyor (Remote Access Software, T1219) ve çoğu EDR/AV için “PUA” (istenmeyen ama zararlı değil) seviyesinde kalıyor.

KOD	İŞLEV
1	Etkileşimli uzak kabuk (interactive shell)
3	Tuş vuruşu, fare olayı ve pano verisini dışarı sızdırır
5	/upload'a dosya / desen / izin yükler, yolları loglar
6	Tüm OS'lerde Chrome ve Brave süreçlerini sonlandırır
7	[T1219] AnyDesk indirip çalıştırır — tam GUI erişimi açar
8	C–G sürücülerinde *.env dosyalarını tarar ve yükler

FAZ 08

PASSWORD STORES (T1555.003)

IMPAIR DEFENSES (T1562.001)

"pow" — Tarayıcı Kimlik Bilgisi Hırsızlığı ve Tsunami

Windows

Local State → os_crypt.encrypted_key → DPAPI (CryptUnprotectData) ile çözülür.

Linux / macOS

secretstorage / Keychain üzerinden Safe Storage parolası → PBKDF2 → AES-CBC.

Kredi kartı

Web Data veritabanındaki credit_cards tablosu da hedefte.

› [T1053.005 / T1547.001] Tsunami çerçevesi

Defender exclusion denemesi (Runtime Broker.exe, msedge.exe adlarıyla), scheduled task + Startup kalıcılığı, ve UAC “izin yorgunluğu” sosyal mühendisliği.

ADLI İZ

Üç InvisibleFerret bileşeninde de aynı sabit string: "Updated on 5th of August" — farklı vakaları eşleştirmek için değerli bir imza kaynağı.

DPAPI (Data Protection API): Windows'un, verileri kullanıcı/makine kimliğine bağlı olarak şifreleyip çözen yerleşik servisi · PBKDF2: bir parolayı binlerce kez tekrar hashleyerek güçlü bir şifreleme anahtarına dönüştüren standart algoritma · AES-CBC: yaygın kullanılan simetrik bir şifreleme yöntemi · UAC (User Account Control): Windows'un yönetici izni istediğinde çıkardığı onay penceresi.

FAZ 09

POWERSHELL (T1059.001)

OBFUSCATED FILES (T1027)

Perde Arkası: Sahte Web Uygulaması Açılıyor

POWERSHELL -ENCODEDCOMMAND (BASE64, UTF-16LE)

UwB0AGEAcgB0ACAAIgBoAHQAdABwADoALwAvAGwAbwBjAGEAbABoAG8AcwB0ADoANQAxADcAMwAvACIA

BASE64 DECODE

DECODE EDİLMİŞ HALİ

Start "http://localhost:5173/"

SAHNENİN EN “İNSANI” DETAYI

Kurban, npm install & npm run dev sonrası beklediği gibi çalışan bir gayrimenkul sitesiyle karşılaşır. Arka planda saniyeler içinde kurulan tüm C2 altyapısı bu “her şey normal” anına gizleniyor.

-EncodedCommand: PowerShell'e komutu düz metin yerine Base64 olarak vermeyi sağlayan bir parametre — komut satırı loglarında düz metin görünmez, ek bir çözme adımı gerektirir.

FAZ 10

SCREEN CAPTURE (T1113)

INPUT CAPTURE (T1056.001)

İkinci, Bağımsız Gözetim Katmanı

```
process cmd.exe /d /s /c "npm install --save node-global-key-listener \
  screenshot-desktop sharp --no-warnings --no-save --loglevel silent"
```

- › **node-global-key-listener**
OS seviyesinde global klavye yakalama; WinKeyServer.exe adlı native ikili diske yazılıp çalıştırılıyor.
- › **screenshot-desktop + sharp**
Ekran görüntüsü alınıp küçültülüyor — bant genişliğini ve anomali tespiti riskini azaltıyor.

NEDEN İKİNCİ BİR KATMAN

Önceki Python tabanlı keylogger'in üzerine eklenen bu katman, muhtemelen yedeklilik ya da farklı bir operatör/araç seti tarafından tetiklenen paralel bir toplama hattı.

FAZ 11

NETWORK SHARE DISCOVERY (T1135)

FILE/DIR DISCOVERY (T1083)

Elle Keşif ve Operasyonun Kapanışı

```
process cmd.exe /d /s /c "dir "U:""  
process cmd.exe /d /s /c "dir "%USERPROFILE%\Desktop"  
process cmd.exe /d /s /c "taskkill /F /IM node.exe" # +4 saniye sonra
```

İNSAN ELİ

Yaklaşık 30 dakikalık hareketsizlik sonrası operatör ardışık, tek tek sürücü harfi deneyen dir komutlarıyla elle keşif yapıyor — U ve V gibi harfler tipik olarak ağ paylaşımlarına atanır, yani operatör bir ağ paylaşımı arıyor olabilir. Son komuttan 4 saniye sonra kendi arka kapısını kapatıp çekiliyor.

FAZ 12

KAMPANYA ÖLÇEĞİ

Geniş Resim: Bu Tek Bir Kurban Değildi

- › Bu tek rakam bile kampanyanın hedefli/tekil bir saldırı değil, eşzamanlı, çok kurbanlı, ölçeklenebilir bir operasyon olduğunu gösteriyor.

13 EŞZAMANLI KURBAN

Ele geçirilen InvisibleFerret WebSocket C2 trafiğinin incelenmesi, aynı operatörün eşzamanlı olarak 13 farklı kurban hakkında veri topladığını ortaya koydu — Hindistan, ABD, Fransa ve diğer bölgelerden. Dağılım: 10 macOS, 2 Windows, 1 Ubuntu.

Rakamlarla Vaka

Rapordaki kapanış istatistikleri — saldırının hızını ve ölçeğini somutlaştırır.

00:00:54

Time to Discovery

İlk otomatik Suricata alarmına kadar geçen süre

00:51:21

Time to Hands-On

Operatörün elle klavye başına geçmesine kadar geçen süre

13

Eşzamanlı Kurban

10 macOS · 2 Windows · 1 Ubuntu — aynı operatör

3

Payload Ailesi

OtterCookie · InvisibleFerret · Tsunami — tek zincirde birleşti

Neden Bu Kadar Etkili?

Kullanılan tekniklerin hiçbirisi tek başına devrimsel değil — aslında etkileyici olan, bunların nasıl birleştirildiği.

› 1. Güvenin istismarı

Saldırı bir e-posta eki değil, kurbanın kendi isteğiyle başlattığı bir iş akışı.

› 2. Meşru araçların silahlandırılması

axios, socket.io-client, AnyDesk, pyWinhook — hiçbirisi zararlı yazılım değil, hepsi herkesin kullandığı araçlar.

› 3. Katmanlı, sabırlı gizleme

Font dosyası kılığı, obfuscator.io, 64 kez iç içe exec() — tek başına aşılmaz değil ama üst üste bindirildiğinde her katman ayrı çözülmeli.

Savunma Ne Yapmalıydı? — Teknik Kontroller

Her satır, gördüğümüz bir ATT&CK tekniğini doğrudan bir savunma kontrolüne bağlıyor — bu bir dilek listesi değil, bugün uygulanabilir bir kontrol listesi.

ATT&CK TEKNIĞİ	VAKADAKİ KARŞILIĞI	BLUE TEAM ÖNERİSİ
T1036.008 Masquerading	fa-solid-400.woff2 adlı JS backdoor	Interpreter (node/python) komut satırında beklenmeyen dosya uzantısı geçiren süreçleri EDR ile işaretle.
T1027 Obfuscation	obfuscator.io JS, zlib+base64+reverse Python	Yüksek entropili / anormal uzunlukta node -e, python -c komut satırlarını tespit eden davranışsal kural yaz.
T1497.001 Sandbox Evasion	wmic / system_profiler / /proc/cpuinfo sorguları	Analizi gerçek donanımda yap; dev workstation'larda bu sorguların ardından dış bağlantı açan süreçleri izle.
T1071.001 C2 / WebSocket	socket.io ile 1271 portuna kalıcı bağlantı	Geliştirici uç noktalarından kurumsal olmayan IP'lere giden ham WebSocket trafiğini engelle / uyar.
T1555.003 Credential Theft	Chromium os_crypt yeniden uygulaması	Kurumsal parola yöneticisi zorunlu kıl, tarayıcıda şifre kaydetmeyi GPO ile kapat; Login Data dosyasına erişimi izle.
T1562.001 Defender Exclusion	Runtime Broker.exe adında exclusion denemesi	Defender exclusion listesi değişikliklerini yüksek öncelikli, nadir görülen bir olay olarak logla ve anında uyar.
T1041 Exfiltration	/upload, /keys uç noktalarına multipart POST	Dev laptop'larda çıkış trafiğini yalnızca onaylı paket kayıt defterleri/CI uç noktalarıyla sınırla (egress allowlist).

Savunma Ne Yapmalıydı? — Süreç ve İnsan Katmanı

› İşe alım sürecini izole et

Teknik mülakat görevleri asla kurumsal cihazda/kimlik bilgilerine erişimi olan bir ortamda çalıştırılmamalı — GitHub Codespaces gibi geçici, tek kullanımlık bulut sandbox'ları önerilmeli.

› npm install'a güvenme

--ignore-scripts varsayılan politika olmalı; bağımlılık taraması (npm audit, Socket.dev benzeri araçlar) CI'a gömülmeli.

› Least privilege + UAC yorgunluğu

Geliştirici hesapları standart kullanıcı olmalı, yönetici işlemleri için JIT/PIM elevation kullanılmalı — sürekli UAC istekleri normalde başarısız olmalı.

› Davranışsal tespit yatırımı

Bu vakayı yakalayan şey imza değil, ağ trafiği deseni (Suricata) — EDR + NDR yatırımı imza tabanlı AV'den daha değerli.

› Farkındalık eğitimi

“Bu normal görünüyor” refleksi tam olarak burada istismar edildi — geliştiricilere özel, tedarik zinciri odaklı güvenlik farkındalığı eğitimi şart.

› Tespit mühendisliği çıktısı

Bu vaka temelinde muhtemel iki yeni kural: Suricata — socket.io/Nodster C2 POST deseni için imza; YARA — üç payload'da da görülen sabit “xUpdateDate / Updated on 5th of August” string'i için.

Teşekkürler.

Sorularınız ve tartışmak istediğiniz noktalar için söz sizde.

› **Kaynak rapor**

"Job Interview or North Koreans? A Contagious Interview Intrusion" — MISP olay raporu

› **Bu sunumun kapsamı**

Komut seviyesinde saldırı zinciri, her adımda ilgili MITRE ATT&CK tekniği, ve kapanışta Blue Team savunma çerçevesi

› **Sonraki adım**

İzole, zararsız bir lab ortamında kurban/operatör perspektifini canlı gösteren hands-on demo